

AI Deployment Approval Pack

Consulting Review — Partner Scenario Assessment

Prepared by: Petra Mifka Date: 24 March 2026 Status: Training exercise — not legal advice

Executive Summary

This pack covers four AI deployment scenarios submitted by the exercise partner. Each has been assessed against the EU AI Act (Regulation 2024/1689) to determine the applicable risk tier, compliance obligations, and deployment decision. One case requires outright refusal as proposed. Two require conditional approval with documented controls. One can proceed with standard good-practice measures.

Case	Classification	Decision
Case 1 MediScreen	PROHIBITED — Art. 5(1)(f)	Deny as proposed. Redesign required.
Case 2 BenefitCheck	HIGH-RISK — Annex III, Area 5	Approve with controls. Deployer obligations must be met first.
Case 3 ShopBot	LIMITED RISK — Art. 50 transparency	Approve with controls. AI disclosure required before launch.
Case 4 AdOptimiser	MINIMAL RISK — no Annex III trigger	Approve. Good-practice AI inventory recommended.

Case 1 — MediScreen

Classification: PROHIBITED — Article 5(1)(f) EU AI Act

Scenario

A private hospital group proposes deploying a third-party tool that analyses facial expressions and vocal tone during mandatory staff video check-ins to generate a per-employee stress and disengagement index. Team leads receive a dashboard summary. Employees do not see their own scores and have no override mechanism.

Architecture & Role Map

Trigger	Mandatory weekly team video check-in
AI behaviour	Analyses facial expression and vocal tone; produces per-employee stress/disengagement index
Human review	None at individual level — team leads see aggregated dashboard; no employee override
Provider	Third-party wellness tool vendor
Deployer	MediScreen HR department
Output	Per-employee index score surfaced to line management

Compliance Analysis

Emotion recognition in the workplace is explicitly prohibited under Article 5(1)(f). The prohibition covers AI systems that infer emotional states from biometric signals — including facial expressions and vocal tone — of persons in a workplace context. The vendor's marketing framing as a 'wellbeing tool' and the contractual disclaimer that scores are not used in appraisals are legally irrelevant. The prohibition is triggered by what the system does, not how it is labelled or how the deployer intends to use the output. The absence of employee visibility over their own scores and the lack of any override mechanism compound the fundamental rights concern but are not required to establish the prohibition.

Decision: DENY AND REDESIGN

The system as proposed cannot be approved. The only compliant path is a full redesign that removes individual biometric inference. A lawful alternative could include: an anonymised, aggregate-only wellbeing pulse survey (no per-employee profiling); a voluntary self-report wellness tool with employee-controlled data; or a non-AI enhanced EAP (Employee Assistance Programme) referral pathway. Any replacement tool should be reviewed against GDPR Article 9 (special category data) and the relevant works council co-determination requirements under German and applicable member-state law.

Legal team should verify: final determination on whether the vendor's aggregation approach, if modified, could bring the tool outside Article 5 scope; works council consultation obligations (BetrVG §87 in Germany).

Case 2 — BenefitCheck

Classification: HIGH-RISK — Annex III, Area 5 (essential public services)

Scenario

A regional German municipality is procuring an off-the-shelf AI system to assist caseworkers in processing social housing subsidy applications. The system produces an approve/review/decline recommendation. Caseworkers must confirm or override before any decision is issued and all decisions are logged. The vendor has provided CE marking documentation. The municipality's legal team has not yet reviewed it. Approximately 11,000 applications are processed annually.

Architecture & Role Map

Trigger	New social housing subsidy application submitted
AI behaviour	Ingests income, household, rental history, prior claims data; outputs eligibility recommendation (approve / review / decline) with rationale
Human review	Mandatory: caseworker confirms or overrides before decision is issued; caseworker ID logged against every decision
Provider	Third-party off-the-shelf AI vendor (CE marking issued)
Deployer	Regional municipality — public authority
Output	Logged decision record tied to caseworker; applicant notified of outcome

Compliance Analysis

AI systems that determine or materially influence access to essential public services and social benefits fall within Annex III, Area 5. This is a high-risk system. The human confirmation step is a material positive — it satisfies the human oversight design requirement in principle. However, the municipality as deployer carries obligations that have not yet been discharged: (1) the CE marking and technical documentation must be reviewed by the legal team before deployment; (2) as a public authority deploying a high-risk AI system in an Annex III area, the municipality must conduct a Fundamental Rights Impact Assessment (FRIA) prior to first use; (3) caseworkers must receive documented training on the system's limitations and the exercise of override; (4) a monitoring and incident reporting mechanism must be established; (5) the system must be registered in the EU database if not already done by the vendor.

Decision: APPROVE WITH CONTROLS

Deployment may proceed once the following conditions are met: legal review of CE marking and technical documentation completed and signed off; FRIA conducted and documented; caseworker training programme delivered and recorded; incident reporting and monitoring procedure established; confirmation that the vendor's EU database registration covers this deployment context. The 40% processing efficiency gain is a legitimate operational benefit, but cannot be the basis for bypassing deployer obligations.

Legal team should verify: whether the vendor's CE marking covers this specific deployment context or requires a supplementary conformity assessment; FRIA scope under Article 27; German administrative law requirements for automated or AI-assisted administrative decisions (VwVfG §35a considerations).

Case 3 — ShopBot

Classification: LIMITED RISK — Article 50 transparency obligation

Scenario

A Berlin-based online retailer has deployed a conversational AI assistant — ShopBot — that handles sizing, delivery, returns, complaints, and partial refunds up to €30. It uses a human-sounding name and avatar. It does not identify itself as an AI. The vendor has placed AI disclosure obligations on the retailer. Approximately 18,000 interactions occur monthly.

Architecture & Role Map

Trigger	Customer initiates chat via website or app
AI behaviour	Third-party LLM via API handles queries end-to-end; proactively recommends products; initiates partial refunds up to €30 autonomously
Human review	None during interaction; refunds under €30 require no human approval; escalation path not described
Provider	Third-party LLM vendor (disclosure obligation contractually passed to retailer)
Deployer	FashionDirect (retailer) — holds Article 50 obligation
Output	Customer service response, product recommendation, or refund action; no persistent consumer profile retained by the tool

Compliance Analysis

Article 50(1) requires that operators of AI systems designed to interact with natural persons inform those persons that they are interacting with an AI, unless it is obvious from context. A human-sounding name and avatar with no disclosure is a direct violation. The vendor's contractual pass-through does not eliminate the obligation — FashionDirect as deployer is responsible. The partial refund capability (up to €30 without human review) and complaint handling are operationally relevant but do not elevate the tier. This system does not fall within Annex III. Separately, the human-sounding persona may engage consumer protection considerations under the Unfair Commercial Practices Directive and GDPR transparency obligations, which legal team should assess.

Decision: APPROVE WITH CONTROLS

Deployment may continue subject to the following: (1) ShopBot must clearly identify itself as an AI at the start of every interaction — a one-line disclosure at session open is sufficient; (2) the human-sounding avatar is permissible provided the AI disclosure is made proactively; (3) the retailer should document a clear escalation path for complaints or refund disputes that exceed the €30 autonomous threshold; (4) vendor terms should be reviewed to confirm the LLM provider's own Article 50 position. The fix is low-cost and low-complexity. There is no basis to deny deployment once disclosure is in place.

Legal team should verify: compliance with UCP Directive on AI persona marketing; GDPR Article 13/14 transparency notices covering AI-generated product recommendations.

Case 4 — AdOptimiser

Classification: MINIMAL RISK — no Annex III trigger, internal tool only

Scenario

A Hamburg-based digital marketing agency has built an internal AI tool that automatically adjusts bidding strategy, copy variants, and audience targeting for paid social campaigns. It operates on aggregated platform data returned via API. No individual consumer profiles are created or retained. Account managers can override any parameter at any time. The tool is not sold or licensed to third parties.

Architecture & Role Map

Trigger	Automated every 6 hours based on campaign performance signals
AI behaviour	Analyses historical CTR, conversion rates, aggregated platform data; recommends or auto-applies bid, copy, and targeting adjustments
Human review	Account managers review weekly performance reports; can override any parameter at any time
Provider	The agency itself (internally built, not placed on market)
Deployer	Same entity — internal use only
Output	Campaign parameter adjustments applied via platform API; no individual consumer data retained

Compliance Analysis

AdOptimiser does not fall into any Annex III category. It does not interact with end users, does not make decisions affecting natural persons' access to services or rights, and operates exclusively on aggregated platform data. No transparency obligation under Article 50 is triggered. As an internally built tool not placed on the market or put into service for third parties, the provider/deployer distinction collapses to a single entity with no mandatory pre-market obligations. Human override is available throughout. The only parallel risk worth flagging is whether the audience targeting logic, when applied at scale, could inadvertently produce discriminatory ad delivery patterns — a Meta/Google platform-level concern rather than an AI Act obligation, but worth including in any responsible AI use policy.

Decision: APPROVE

The tool can proceed as described. Recommended good-practice measures: include AdOptimiser in the agency's internal AI system inventory; document the override policy and version control for model updates; if the tool is ever productised or licensed to clients, a full AI Act classification review is required at that point.

Legal team should verify: whether any client contracts require disclosure of AI-assisted campaign management; ad platform policy compliance (Meta, Google) on automated bidding tools.

Stretch: BenefitCheck — Implementation Roadmap

BenefitCheck was selected as the strongest high-risk case for deeper consulting treatment.

What the provider needs before market placement

- 1. Conformity assessment completed and CE marking issued for the specific use case (social benefit eligibility in EU public sector context).
- 2. Technical documentation prepared per Article 11 and Annex IV: system architecture, training data governance, accuracy and robustness metrics, known limitations.
- 3. Automatic logging capability enabled: the system must be capable of generating logs sufficient to allow post-hoc review of individual recommendations.
- 4. Instructions for use prepared for deployers: covering intended purpose, known limitations, required human oversight arrangements, and data input specifications.
- 5. System registered in the EU AI Act public database (Article 71).

What the deployer (municipality) needs before first use

- 6. Legal review of CE marking documentation and technical summary — confirm scope covers this deployment.
- 7. Fundamental Rights Impact Assessment (FRIA) conducted and documented per Article 27.
- 8. Caseworker training programme: covering system purpose, limitations, how to read the recommendation rationale, and when and how to override.
- 9. Monitoring procedure established: including KPIs for override rate, demographic disparity tracking, and escalation path for anomalies.
- 10. Incident reporting mechanism in place per Article 73: serious incidents or unexpected behaviour to be reported to the market surveillance authority.
- 11. Data processing agreement with the vendor reviewed under GDPR (applicant data as special category in some cases).

Evidence to request from the vendor

- 12. Copy of the full conformity assessment and technical documentation (not just the summary provided to date).
- 13. Training data governance policy: sources, quality controls, demographic representation, and bias testing results.
- 14. Accuracy and fairness metrics: false positive and false negative rates for approve/decline outcomes, broken down by applicant demographic where available.
- 15. Audit log samples: evidence that the logging capability functions correctly and that logs are accessible to the deployer.
- 16. Incident history: any known errors, malfunctions, or complaints from prior deployments in comparable public authority contexts.

— Partner Scenarios below reviewed by Carolina Nami —

Partner Scenario Assessment — Petra

Four client scenarios submitted by Carolina Figueiredo, reviewed against EU AI Act (Regulation 2024/1689). One prohibited, one high-risk, one limited risk, one minimal risk.

Case	Classification	Decision
Case ARetailBank	PROHIBITED — Art. 5(1)(b) and 5(1)(c)	Deny as proposed. Redesign required.
Case BLogisticsHire	HIGH-RISK — Annex III, Area 4 (employment)	Approve with controls. Human review of all exclusions required.
Case CTravelBot	LIMITED RISK — Art. 50 transparency	Approve with controls. AI disclosure required immediately.

Case DTicketTriage	MINIMAL RISK — no Annex III trigger, internal tool	Approve. Add to internal AI inventory as good practice.
-----------------------	--	---

Case A — RetailBank

Classification: PROHIBITED — Article 5(1)(b) and Article 5(1)(c) EU AI Act

Scenario

A national retail bank wants to automate loan application decisions to reduce branch costs. The proposed system ingests behavioural signals from customers' mobile banking apps — including spending patterns, time-of-day transaction habits, and social network data purchased from a third-party broker — to produce a hidden creditworthiness modifier. This modifier adjusts the visible interest rate offer without the customer's awareness. No explanation is surfaced to the applicant and no human reviews the adjustment before it is applied. The customer base is predominantly lower-income households across several EU member states.

Architecture & Role Map

Trigger	Customer submits loan application via mobile banking app
AI behaviour	Ingests behavioural and social network signals; produces hidden interest rate modifier applied without disclosure or human review
Human review	None — modifier applied fully automatically; no disclosure to customer
Provider	AI scoring vendor (third-party); data broker (separate supply chain)
Deployer	Retail bank
Output	Adjusted interest rate offer presented to customer with no indication of AI-based modification

Compliance Analysis

Two prohibited practices stack in this scenario. First, Article 5(1)(b) prohibits AI systems that deploy subliminal techniques beyond a person's conscious awareness to materially distort their behaviour in a way that causes or is likely to cause significant harm. A hidden modifier that silently adjusts the interest rate a customer receives — based on behavioural and social signals the customer is unaware are being used — is precisely this. The customer cannot meaningfully evaluate or contest the offer because they do not know it has been altered. Second, Article 5(1)(c) prohibits AI systems that exploit the vulnerabilities of specific groups to materially distort behaviour in a harmful way. Targeting predominantly lower-income households with a covert pricing mechanism engages this prohibition directly. Neither prohibition requires proof of intent to harm — the design alone is sufficient to trigger them. The use of third-party social network data as a scoring input also raises serious GDPR concerns (lawful basis, special category inference) but those are secondary to the AI Act prohibition.

Decision: DENY AND REDESIGN

The system cannot be approved in any form as designed. The lawful redesign path requires removing the hidden modifier entirely and replacing it with a transparent, disclosed credit risk model: (1) the basis on which pricing is determined must be disclosed to the applicant; (2) social network data from third-party brokers must be removed from the input set unless a valid GDPR lawful basis can be established; (3) a human review step must be introduced for any AI-assisted rate determination; (4) customers must be given a meaningful right to explanation and contestation under GDPR Article 22. The efficiency gains the bank seeks can be pursued through a lawful, disclosed AI-assisted underwriting model — the prohibition is on covert manipulation, not on AI in credit assessment per se.

Legal team should verify: GDPR Article 22 automated decision-making obligations; lawful basis for third-party social data use; Consumer Credit Directive disclosure requirements; EBA guidelines on internal governance and model risk.

Case B — LogisticsHire

Classification: HIGH-RISK — Annex III, Area 4 (employment and workers management)

Scenario

A large logistics company operating across five EU countries wants to modernise its driver recruitment pipeline. The proposed system ingests CVs, structured application data, and video interview recordings to rank candidates automatically and produce a shortlist. Human recruiters review only shortlisted candidates. No recruiter reviews applicants scored below the threshold. The system is expected to improve consistency across regional hiring teams and reduce manual HR workload.

Architecture & Role Map

Trigger	New driver job application submitted to recruitment pipeline
AI behaviour	Processes CVs, application data, and video interviews; scores and ranks candidates; generates shortlist automatically
Human review	Shortlisted candidates only; applicants below threshold receive no human review — AI exclusion is final
Provider	Third-party recruitment AI vendor
Deployer	Logistics company (HR department)
Output	Ranked shortlist passed to recruiters; rejected applicants notified without individual human review of their application

Compliance Analysis

AI systems used in recruitment and selection of persons fall squarely within Annex III, Area 4. This is a high-risk system and cannot be approved without controls. The central compliance failure is the human oversight arrangement. Article 14 requires that high-risk AI systems are deployed such that humans can effectively oversee, intervene in, and override outputs. Here, only shortlisted candidates receive human review. Applicants scored below the threshold are rejected entirely on the basis of an automated score — the AI is making the final exclusion decision, not the recruiter. This is the structural equivalent of the Q15 housing benefit problem: a human is present in the loop for one population (shortlisted) but absent for the population that faces the most consequential outcome (rejected). Additionally, the use of video interview recordings raises GDPR Article 9 concerns if the system processes biometric or inferred demographic data, and the Equal Treatment Directive applies to any discriminatory patterns in the scoring model.

Decision: APPROVE WITH CONTROLS

Deployment is not approved as described. The system may be approved subject to the following mandatory redesign and controls: (1) all applicants below the threshold must receive at minimum a sampling-based human review, and any final rejection decision must be confirmed by a recruiter, not issued automatically by the AI; (2) conformity assessment and CE marking must be in place and reviewed by the legal team before deployment; (3) bias testing on training data must be documented, with results broken down by protected characteristics; (4) applicants must be informed that AI is used in the recruitment process; (5) a logging mechanism must record all AI scores and final recruiter decisions for auditability; (6) the logistics company must establish an incident reporting mechanism. The consistency and efficiency benefits the client seeks are achievable within a compliant architecture — the fix is in the process design, not the technology.

Legal team should verify: GDPR Article 9 and biometric data processing in video analysis; Equal Treatment Directive and national employment discrimination law; vendor conformity documentation scope and coverage.

Case C — TravelBot

Classification: LIMITED RISK — Article 50 transparency obligation

Scenario

An online travel agency wants to deploy a 24/7 AI customer support solution handling booking modifications, refund requests, and destination FAQs in 12 languages. The conversational AI presents itself in a friendly first-person style and does not proactively inform users they are speaking with an AI. The agency argues that disclosing AI status will reduce customer satisfaction scores. The system replaces a portion of the human agent capacity and handles interactions end-to-end.

Architecture & Role Map

Trigger	Customer opens support chat on website or app
AI behaviour	Handles bookings, refunds, FAQs end-to-end in first-person style with no AI disclosure; presents as if human agent
Human review	None during interaction; escalation path to human agent not described
Provider	Third-party LLM vendor (disclosure obligation contractually passed to deployer)
Deployer	Online travel agency — holds Article 50 obligation toward customers
Output	Customer service response, booking modification, or refund action; customer unaware they are not speaking with a human

Compliance Analysis

Article 50(1) requires that operators of AI systems intended to interact with natural persons inform those persons that they are interacting with an AI, clearly and before or at the point of interaction, unless it is obvious from context. A system presenting in first-person style with no disclosure is a direct violation. The agency’s customer satisfaction argument has no legal standing — the disclosure duty is not optional and cannot be waived on commercial grounds. The system does not fall within Annex III and no high-risk classification applies; the tier is limited risk, with transparency as the operative obligation. The travel agency as deployer holds the Article 50 obligation regardless of how vendor terms allocate responsibility internally. Separately, the first-person human-like persona may engage the Unfair Commercial Practices Directive if customers are misled about the nature of the service they are receiving. The absence of a described escalation path to a human agent is also a good-practice gap.

Decision: APPROVE WITH CONTROLS

The system can continue operating subject to two immediate actions: (1) a clear AI disclosure must be added at the start of every customer interaction — a single line at session open is sufficient and low-cost to implement; (2) a documented escalation path to a human agent must be established and accessible to customers. The human-sounding name and persona are permissible provided the AI disclosure is made proactively. No Annex III re-classification is required. The fix is simple and should be treated as a pre-launch blocker for any markets not yet live.

Legal team should verify: Unfair Commercial Practices Directive compliance for AI persona marketing; GDPR Articles 13/14 transparency notices for interaction data; consumer protection obligations across the 12 languages and jurisdictions served.

Case D — TicketTriage

Classification: MINIMAL RISK — no Annex III trigger, internal professional tool

Scenario

A B2B SaaS company wants to reduce time spent by its engineering teams on internal ticket triage. The AI system reads new tickets submitted to an internal Jira board by internal staff only, classifies them by type and estimated effort, and assigns a suggested priority label. A human team lead reviews and accepts or overrides the label before any work is scheduled. No external users or personal data are involved. Tickets concern software bugs and feature requests only.

Architecture & Role Map

Trigger	Internal staff submits new ticket to Jira board
AI behaviour	Classifies ticket type, estimates effort, assigns suggested priority label
Human review	Team lead reviews and confirms or overrides label before any work is scheduled — AI suggestion is not binding
Provider / Deployer	Same entity (SaaS company) — internal tool, not placed on market; provider/deployer distinction collapses
Output	Suggested priority label on internal Jira ticket; final scheduling decision made by team lead

Compliance Analysis

TicketTriage does not engage any Annex III category. The system operates on internal technical content only, affects no natural person’s access to services or rights, involves no external users, and processes no personal data beyond what is inherent to staff ticket submissions. No Article 50 transparency obligation is triggered as the system does not interact with end consumers. Human override is mandatory before any work is scheduled — the AI functions as a suggestion engine, not a decision-maker. As an internally built tool not placed on the market, the provider/deployer distinction does not apply. The only parallel consideration is whether ticket content ever includes personal data about external users (for example, bug reports referencing customer accounts), in which case standard GDPR data minimisation principles apply — but this is an existing obligation, not an AI Act trigger.

Decision: APPROVE

The tool can proceed as described. Good-practice recommendations: include TicketTriage in the company’s internal AI system inventory; document the team lead override policy; if the tool is ever productised, licensed to clients, or extended to process customer-facing data, a full AI Act classification review is required before that deployment.

Legal team should verify: GDPR data minimisation if ticket content references customer personal data; client contract obligations if AI-assisted tooling requires disclosure to enterprise customers.

End of approval pack. All classifications are first-pass consulting assessments for training purposes. Final legal interpretation should be verified by qualified EU AI Act counsel.

Partner Scenario Assessment — Petra

Four client scenarios submitted by Elsa Bakiu, reviewed against EU AI Act (Regulation 2024/1689). One prohibited, one high-risk, one limited risk, one minimal risk.

Case	Classification	Decision
Case A - RetailBank	PROHIBITED — Art. 5(1)(b) and 5(1)(c)	Deny as proposed. Redesign required to remove hidden behavioral pricing and ensure transparency and contestability.
Case B - LogisticsHire	HIGH-RISK — Annex III, Area 4 (employment)	Approve with controls. Human review must apply to all final decisions, including rejected candidates.
Case C - TravelBot	LIMITED RISK — Art. 50 transparency	Approve with controls. Clear AI disclosure required at the start of interaction and human escalation must be available.
Case D - TicketTriage	MINIMAL RISK — no Annex III trigger, internal tool	Approve. Maintain human oversight and include in internal AI system inventory as good practice.

Case A — RetailBank

Classification: Prohibited
Relevant AI Act references: Article 5(1)(b), Article 5(1)(c)

Scenario

A national retail bank aims to automate loan pricing decisions using behavioral data. The system introduces a hidden decision layer that modifies financial outcomes without user awareness. Behavioral signals and third-party data are used to influence pricing, while the customer has no visibility or ability to contest the outcome. This creates a scenario where decision-making is both opaque and materially impactful.

Architecture & Role Map

Input	transaction data, behavioral signals, third-party social data
Model	behavioral scoring + pricing adjustment
Output	modified interest rate
Human involvement	none
Provider	external AI vendor + data broker
Deployer	retail bank

Compliance Analysis

From a **system design perspective**, this AI introduces an invisible decision layer that directly alters financial outcomes. The user cannot detect, interpret, or challenge the system's influence.

From a **legal perspective**, two prohibitions are triggered:

- **Article 5(1)(b)**: the system influences user outcomes without awareness, effectively shaping behavior or decisions outside conscious understanding
- **Article 5(1)(c)**: the model disproportionately impacts financially vulnerable users, introducing risk of exploitation

Crucially, the violation stems from the **design of the system itself**, not from how the output is used. The absence of transparency, auditability, and contestability makes the system non-compliant by construction.

The use of third-party social data further increases risk exposure (GDPR, fairness), but is not required to establish the prohibition.

Decision: DENY AND REDESIGN

A compliant architecture would:

- Remove hidden behavioral modifiers
- Restrict features to **financially relevant, explainable variables**
- Introduce:
 - transparent pricing logic
 - user-facing explanations
 - human review for edge cases
 - audit logs for all decisions

The bank can retain AI-assisted pricing, but only if the system is **observable, explainable, and contestable**.

Legal team should verify:

- GDPR Article 22 (automated decision-making)
- Lawful basis for third-party data
- EU Consumer Credit Directive compliance

Case B — LogisticsHire

Classification: HIGH-RISK — Annex III, Area 4 (employment and workers management)

Scenario

A logistics company deploys an AI system to rank job applicants using CVs, structured inputs, and video interviews. The system produces a shortlist. Recruiters review only shortlisted candidates; rejected applicants are excluded automatically.

Architecture & Role Map

Trigger	Candidate submits application
---------	-------------------------------

AI behaviour	Scores and ranks candidates based on multi-modal inputs
Human review	Limited to shortlisted candidates
Provider	Recruitment AI vendor
Deployer	Logistics company
Output	Shortlist for recruiter review; automated rejection for others

Compliance Analysis

This system clearly falls under **Annex III (employment)**, making it high-risk.

From an **engineering perspective**, the issue lies in decision flow design:

- AI is used as a **filter, not a support tool**
- Rejection decisions are effectively **fully automated**

From a **legal perspective**, this conflicts with **Article 14**, which requires effective human oversight. Oversight must be applied where impact is highest. In this case:

- Humans review positive outcomes (shortlisted candidates)
- AI exclusively determines negative outcomes (rejections)

This creates a critical compliance gap, as affected individuals are excluded without human intervention.

Additionally, the use of video data introduces risks related to:

- biometric inference
- bias across protected characteristics

Decision: APPROVE WITH CONTROLS

To achieve compliance, the system must be redesigned:

- Ensure **human validation of all final hiring decisions**, including rejections
- Introduce:
 - full audit trail (AI score + human decision)
 - bias and fairness monitoring
 - clear documentation of system limitations
 - applicant disclosure of AI usage

The system should function as a **decision-support tool**, not an autonomous gatekeeper.

Legal team should verify:

- GDPR implications of video data (potential biometric processing)
- EU Equal Treatment Directive compliance
- Vendor conformity assessment documentation

Case C — TravelBot

Classification: **LIMITED RISK — Article 50 transparency obligation**

Scenario

An online travel agency deploys a conversational AI to handle bookings, refunds, and customer inquiries. The system presents itself in a human-like way and does not disclose that it is AI. Interactions are handled end-to-end without mandatory human involvement.

Architecture & Role Map

Trigger	Customer initiates chat
AI behaviour	Processes queries and executes actions (e.g. refunds, booking changes)
Human review	Not required during standard interaction
Provider	LLM vendor
Deployer	Travel agency
Output	Customer-facing responses and actions without AI disclosure

Compliance Analysis

From an **interaction design perspective**, the system creates ambiguity about whether the user is interacting with a human or a machine.

Under **Article 50**, users must be informed when interacting with AI unless it is obvious. In this case:

- The system uses a human-like persona
- No disclosure is provided
- Users may rely on outputs assuming human involvement

This creates a direct transparency violation.

Importantly, the system does not meet criteria for high-risk classification, as it does not determine access to essential services or rights. The compliance issue is limited to **user awareness and informed interaction**.

Decision: APPROVE WITH CONTROLS

Required Controls

- Introduce **clear AI disclosure at the start of interaction**
- Provide a **human escalation path**
- Maintain logs for traceability and dispute resolution

These changes are low complexity and do not impact core system performance.

Legal team should verify:

- Consumer protection implications (misleading interface design)
- GDPR transparency obligations

Case D — TicketTriage

Classification: MINIMAL RISK — no Annex III trigger, internal professional tool

Scenario

A B2B SaaS company deploys an internal AI system to classify and prioritize Jira tickets. The system suggests labels based on ticket content. A team lead reviews and confirms or overrides all outputs before any action is taken.

Architecture & Role Map

Trigger	Internal staff submits ticket
AI behaviour	Classifies ticket type, estimates effort, assigns suggested priority label
Human review	Classifies type, estimates effort, suggests priority
Provider / Deployer	Mandatory — team lead confirms or overrides
Output	Suggested priority label; final decision made by human

Compliance Analysis

From a **system perspective**, the AI operates strictly as a support tool:

- No autonomous decisions
- No external users
- No impact on rights or access to services

This places it outside Annex III and outside transparency obligations under Article 50.

From a **governance perspective**, the system already includes strong safeguards:

- human-in-the-loop validation
- internal-only usage
- non-binding outputs

The only secondary consideration is whether ticket content may occasionally include personal data. This would trigger standard GDPR obligations but does not affect AI Act classification.

Decision: APPROVE

Governance Recommendations

- Maintain human validation as mandatory
- Document model updates and override patterns
- Include the system in the internal AI inventory
- Reassess classification if system scope expands

Legal team should verify:

- GDPR data minimisation if tickets include customer references
- Contractual disclosure requirements if the tool is externalised